

HiddenTreasury

HiddenTreasury.sol | Solidity ^0.8.20 | OWASP SC Top 10 2026 + SWC Registry

60

RISK SCORE / 100

1. Identificacion del contrato

Proposito	Boveda de depositos con balances por usuario y una tesoreria que el owner puede mover.
Actores	Owner (transferToTreasury/changeOwner), Usuarios (deposit/withdraw).
Flujo de fondos	ETH entra por deposit()/receive(); sale por withdraw() (usuario) o transferToTreasury() (owner, sin limite).

2-4. Hallazgos: clasificacion OWASP / SWC y vector de ataque

#	Riesgo / Causa raiz	Descripcion y vector de ataque	Sev.	SWC	OWASP 2026
1	El owner puede drenar fondos de los usuarios Root: No se segrega la tesoreria del owner de los depositos de usuarios; el privilegio admin alcanza fondos ajenos.	transferToTreasury() permite al owner enviar hasta address(this).balance a cualquier direccion, sin descontarlo de balances[]. Mueve ETH que pertenece contablemente a los usuarios. Vector: El owner transfiere todo el balance a su address; los usuarios quedan con balances[] >0 pero withdraw() revierte por falta de ETH (insolvencia).	High	SWC-105	SC02:2026 Business Logic Errors
2	changeOwner sin validar address(0) Root: Falta require(newOwner != address(0)).	changeOwner() acepta cualquier direccion, incluida address(0), lo que puede dejar el contrato sin owner valido. Vector: Perdida accidental/maliciosa de la administracion.	Low	SWC-105	SC05:2026 Lack of Input Validation

3. Analisis de logica de negocio

withdraw() si respeta Checks-Effects-Interactions (resta antes del call). El riesgo real es la solvencia: el owner puede vaciar el contrato dejando impagables los balances de usuario.

6. Benchmark metrics

2	0	1	0	1	0.90	0.88	1.00	50	60
Total	Critical	High	Medium	Low	Confidence	Precision	Coverage	Time (s)	Risk

Severidad: Critical / High / Medium / Low. Metricas Precision/Coverage/Confidence estimadas (0-1). Risk score agregado por severidad (0-100). Analisis estatico manual; sin ground truth provisto (Gold Standard: N/A).